Matriz de permisos por rol y sensibilidad del dato

SIFTC · HU-FE-07 · Sprint 4 · Criterio CA 1

Versión 1.0 · Celdas PD resueltas · Documento sin firmas

1. Control del documento

Campo	Valor
Historia	HU-FE-07 · Control de acceso por rol y sensibilidad del dato
Corte	Sprint 4
Elaboró	Subgrupo Backend
Fuente de sensibilidad	Diccionario de datos SIFTC
Aprueba	Líder del subgrupo Backend, con confirmación de Diccionario de datos
Estado	Definición cerrada; documento sin firmas
Versión	1.0
Fecha	2026-11-08

2. Propósito

Definir qué puede ver o hacer cada uno de los seis perfiles del sistema, según el recurso y su nivel de sensibilidad. Esta matriz es la referencia para el filtrado del backend (CA 2) y para las pruebas por perfil (CA 3). Las celdas marcadas originalmente como PD fueron resueltas con las decisiones D1 a D4.

3. Perfiles

Perfil	Descripción
Administrador	Gestiona usuarios, roles y parámetros del sistema.
Data Steward	Mantiene el diccionario de datos y las reglas de calidad.
Analista financiero	Calcula, valida y publica métricas.
Gerente / Directivo	Consulta rankings y toma decisiones.
Auditor	Revisa linaje y bitácora, sin edición.
Usuario móvil	Consulta cotizaciones y mantiene su watchlist.

4. Niveles de sensibilidad

Nivel	Criterio	Ejemplos
Pública	Puede verse sin restricción dentro del sistema.	Nombre y sector de la entidad, series OHLC.
Interna	Usuarios autenticados con acceso al sistema.	Código de entidad, IC, valores de métricas, pesos del IC, bitácora.

Confidencial	Datos financieros detallados y posición competitiva.	Utilidad, patrimonio, activos, ingresos, posición general y de sector.
Restringida	Identidad, credenciales y acceso de usuarios.	Usuario, rol, contraseña cifrada, datos personales.

Regla aplicada: si un recurso contiene campos de varios niveles, se asigna el nivel más alto.

5. Matriz de permisos

Leyenda: L = lectura Â· E = escritura, carga o decisiÃ³n Â· â€” = sin acceso.

Recurso	Sensibilidad	Administrador	Data Steward	Analista financiero	Gerente / Directivo	Auditor	Usuario móvil
Catálogo de entidades	Interna	L	L	L	L	L	L
Series OHLC	Pública	L	L	L	L	L	L
IC y valores de métricas	Interna	L	L	L	L	L	L
Ranking general o por dimensiÃ³n, sin posiciÃ³n	Interna	L	L	L	L	L	â€”
PosiciÃ³n en el ranking	Confidencial	L	L	L	â€”	L	â€”
Watchlist personal (ver)	Interna	L	L	L	L	L	L
Watchlist personal (agregar o quitar)	Interna	â€”	â€”	â€”	â€”	â€”	E
Matriz financiera cruda (carga)	Confidencial	E	L	E	â€”	L	â€”
Datos financieros detallados	Confidencial	L	L	L	â€”	L	â€”
AprobaciÃ³n de cÃ¡lculos (bandeja y decisiÃ³n)	Interna	L	L	E	â€”	L	â€”
ParÃ¡metros del sistema	Interna	E	â€”	E	â€”	L	â€”
AuditorÃ-a	Interna	L	â€”	â€”	â€”	L	â€”
GestiÃ³n de usuarios y roles	Restringida	E	â€”	â€”	â€”	â€”	â€”

D1-B: el Gerente / Directivo puede consultar el ranking, pero la posición y el cambio de posición se devuelven en null. La fila nueva â€œAprobaciÃ³n de cÃ¡lculosâ€ refleja HU-BE-05: solo el Analista financiero decide; los perfiles con acceso a la matriz o a datos detallados pueden consultar la bandeja.

D2-A: únicamente el Usuario móvil puede agregar o quitar entidades de su watchlist. D3-A: el Auditor puede leer los parámetros en modo solo lectura; no puede modificarlos y no se exponen credenciales ni configuración de infraestructura. D4-C: la auditoría mínima se registra y se consulta por Administrador y Auditor; no incluye inmutabilidad en este corte.

6. Decisiones D1â€“D5

ID	Decisión	Resultado
D1	¿El Gerente ve la posición en el ranking?	B: ve el ranking, pero sin posición ni cambio de posición.
D2	¿Quién agrega o quita en la watchlist?	A: solo el Usuario móvil.

D3	¿El Auditor lee los parámetros?	A acotada: lectura de pesos, fórmulas y frecuencias; sin secretos; sin escritura.
D4	¿La auditoría se implementa en este corte?	C mínima: eventos críticos y consulta para Administrador y Auditor; sin inmutabilidad.
D5	Clasificación de la columna acción de auditoría y watchlist	Interna para ambos recursos; confirmación formal del Diccionario de datos fuera de este documento.

7. Estado de implementación

La definición de permisos ya no tiene celdas PD. El estado de implementación se informa por separado para no declarar como terminado lo que aún no está en código.

Recurso o actividad	Estado	Observación
D1-B: ranking y posición	Implementado	Restricción de roles y null para Gerente; desplegado en código.
D2-A: watchlist	Implementado	GET para los seis perfiles; POST/DELETE solo Usuario móvil.
D3-A: parámetros para Auditor	Acordado, no implementado	Falta GET de parámetros y lectura de solo lectura.
D4-C: auditoría mínima	Acordado, no implementado	Requiere registrar eventos, GET de auditoría y GRANT SELECT.
HU-BE-05: aprobación de cálculos	Código preparado	Script-19 y endpoints .NET listos; falta aplicarlos y desplegarlos en Neon.
Matriz cruda: lectura para Data Steward y Auditor	No implementado	Hoy solo existe la carga.
Datos financieros detallados	No implementado	No hay endpoint que los exponga.
Filtrado por sensibilidad campo a campo	No implementado	La autorización actual es por rol.
Pruebas por perfil	No implementado	No existe proyecto de pruebas en el repositorio.
Gestión de usuarios y roles	Parcial	Registro implementado; listado y edición no existen.

8. Aprobación

Rol	Nombre	Firma	Fecha
Líder del subgrupo Backend			
Diccionario de datos			
Docente (si lo solicita)			

Este documento se emite sin firmas. Las firmas se gestionan en la copia oficial de aprobación.

9. Pendientes externos

- Aprobación formal del Diccionario de datos fuera de este documento: confirma D5 y la clasificación Interna de auditoría y watchlist.
- Aprobación formal del Docente fuera de este documento: confirma D4-C para este corte.
- Implementación de D3-A y D4-C en la API .NET.
- Aplicación de Script-19 y de los endpoints de aprobación en Neon.
- Endpoints de matriz cruda y datos financieros detallados para Data Steward y Auditor.
- Filtrado por sensibilidad campo a campo y pruebas por perfil.

10. Observaciones

- Un perfil sin permiso sobre un recurso debe recibir 403, no datos vacíos.
- Los datos de la watchlist solo son visibles para el usuario propietario.
- Las filas de posición se ocultan para Gerente; el ranking sigue disponible sin posición.
- La auditoría mínima no es inmutable en este corte; no debe venderse como anti-manipulación.
- Power BI no debe recibir SELECT sobre tablas pendientes de aprobación.